Étude de cas comparative : Du Ver Morris à WannaCry

UE SEC102 – CNAM Nouvelle Aquitaine

L'évolution de la menace cyber

1. Introduction : La perte de l'innocence numérique

Le 2 novembre 1988, le paysage numérique a connu son premier séisme. À cette époque, le réseau **ARPANET** (ancêtre d'Internet) ne comptait qu'environ **60 000 ordinateurs**, principalement au sein d'un cercle restreint d'universités et d'organismes gouvernementaux. Les utilisateurs évoluaient dans un climat de confiance implicite, quasi académique. En 2017, ce décor s'est métamorphosé en un champ de bataille mondial où des milliards d'appareils sont interconnectés dans un environnement intrinsèquement hostile.

L'objectif de cette étude est de retracer cette transition historique : comment sommes-nous passés d'une **« expérience intellectuelle »** maladroite à une **« arme numérique mondiale »** capable de paralyser des services vitaux ? Ce passage d'un réseau basé sur la confiance à un paradigme de menace permanente illustre la fin de l'innocence numérique, forçant la cybersécurité à devenir une priorité régalienne.

---

2. Le Ver Morris (1988) : L'expérience qui a mal tourné

Robert Tappan Morris, étudiant de 23 ans à l'université de Cornell, souhaitait initialement mesurer la taille du réseau. Pour masquer son origine, il lança son programme depuis un terminal du **MIT**. Cependant, une erreur de conception transforma ce test de pénétration en la première infection à grande échelle.

Les 3 vecteurs de propagation principaux

Le ver exploitait des vulnérabilités critiques des systèmes UNIX pour se répliquer de manière autonome :

- **Vulnérabilité Sendmail (Mode DEBUG) :** En exploitant cette fonction, le ver pouvait envoyer son propre code source sur une machine distante et, via un shell, ordonner sa **compilation locale**. C'est cette capacité à s'auto-compiler sur la cible qui assurait sa portabilité technique.
- **Dépassement de tampon (Buffer Overflow) :** Le ver visait l'utilitaire *finger*. En envoyant une quantité de données supérieure à ce que la mémoire pouvait contenir, il parvenait à **écraser l'adresse de retour (return address)** en mémoire pour forcer l'exécution de son propre code malveillant.
- **Faiblesse des mots de passe :** À l'aide d'un dictionnaire de seulement 900 mots de passe, le ver tentait de forcer les accès via les commandes **rsh** et **rexec** pour se copier sur d'autres segments du réseau.

Impact et conséquences techniques

Le ver Morris a infecté environ **6 000 machines**, soit **10 % de l'Internet de l'époque**. Bien que conçu pour vérifier si une machine était déjà infectée, Morris craignait que les administrateurs ne créent de "fausses réponses" pour bloquer le ver. Il injecta donc une part d'aléatoire : le ver se réinfectait **1 fois sur 7** même si la machine répondait "oui". Cette réinfection constante a saturé la mémoire et les processus, provoquant un **déni de service (DoS)** accidentel.

Il a fallu **15 heures** au ver pour paralyser 2 000 machines aux États-Unis. Ce choc a forcé la création du **CFAA** (*Computer Fraud and Abuse Act*) et du premier **CERT** (Centre d'alerte et de réaction aux attaques informatiques).

---

3. WannaCry (2017) : L'ère des rançongiciels destructeurs

WannaCry marque l'avènement du **« cryptoworm »** : un ver dont la charge utile est un rançongiciel. Apparu le 12 mai 2017, il a été attribué au **groupe Lazarus** (lié à la Corée du Nord). Son efficacité redoutable reposait sur l'exploit **"EternalBlue"**, une vulnérabilité du protocole SMB volée à la NSA par les *Shadow Brokers*.

L'impact sur le National Health Service (NHS)

Le NHS britannique fut l'une des victimes les plus visibles, illustrant le passage de la gêne informatique au risque vital.

« 19 000 rendez-vous ont été annulés et 5 hôpitaux ont dû fermer leurs urgences. Si le coût total pour le NHS est estimé à **92 millions de livres** (incluant la restauration informatique), la perte directe d'activité est évaluée à **5,9 millions de livres** par l'analyse rétrospective. »

Malgré ce chaos, le système a fait preuve de résilience : aucune augmentation significative de la mortalité n'a été relevée, les soignants étant repassés manuellement au papier et au stylo.

Le "Kill Switch" et Marcus Hutchins

L'attaque fut ralentie par le chercheur Marcus Hutchins. Il découvrit que le ver interrogeait un domaine absurde avant de s'exécuter : iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com. Ce mécanisme servait probablement de détection de "sandbox" (si le domaine répondait, le ver croyait être dans un environnement de test et s'arrêtait). En enregistrant ce domaine pour **10,96 $**, Hutchins activa par inadvertance un interrupteur d'arrêt mondial.

La vitesse de propagation fut sans commune mesure avec 1988 : WannaCry a infecté **200 000 ordinateurs** dans 150 pays en seulement **7 heures et 19 minutes**.

---

4. Analyse comparative : Confrontation technique et stratégique

Caractéristique	Ver Morris (1988)	WannaCry (2017)
Motivation	Recherche / Mesure du réseau	Chaos étatique / Financière (Bitcoin)
Type de logiciel	Ver expérimental	Rançongiciel (Cryptoworm)

Vecteur technique	Sendmail, Finger, rsh	SMB (EternalBlue / MS17-010)
Conséquence majeure	Saturation des ressources (DoS)	Chiffrement des données (Lock)
Réponse légale	CFAA et création du CERT	NIS2, Cyber Resilience Act (CRA), Reporting 24h

Cette comparaison souligne une accélération phénoménale de la menace : là où Morris mettait 15 heures pour toucher 2 000 postes, WannaCry en frappait 100 fois plus en deux fois moins de temps.

---

5. Les leçons apprises : De la vulnérabilité à la résilience

Pour un futur expert en sécurité, trois enseignements se dégagent de ces crises :

1. **Le poids de la Dette Technique :** Microsoft avait publié le correctif **MS17-010** deux mois avant WannaCry. Pourtant, l'attaque a réussi car de nombreuses organisations (comme le NHS) utilisaient des systèmes obsolètes (Windows XP) ou ne pouvaient pas appliquer les patchs sans risquer de casser des applications métier coûteuses.

2. **Du Trust implicite au Zero Trust :** En 1988, le réseau était un "club" de confiance. Aujourd'hui, nous sommes dans un environnement adversarial. Le passage au **Zero Trust** impose de ne plus accorder de confiance basée sur la position réseau, mais de vérifier chaque identité et chaque terminal, car le périmètre traditionnel a disparu.

3. **L'automatisation de la défense :** La vélocité de WannaCry montre que la réaction humaine est trop lente. La défense doit désormais s'appuyer sur des outils automatisés de détection et de réponse pour contenir une épidémie numérique avant qu'elle ne devienne systémique.

---

6. Conclusion et Perspectives

L'évolution du Ver Morris vers WannaCry montre que l'informatique n'est plus un outil support, mais le système nerveux de nos sociétés. Cette transformation a forcé les États à légiférer de manière agressive. En 2024, des régulations comme la directive européenne **NIS2** imposent désormais un signalement des incidents sous 24 heures, tandis que le **Cyber Resilience Act (CRA)** responsabilise les fabricants tout au long du cycle de vie des produits.

Cependant, la technique ne résoudra pas tout seule. La lutte contre la "dette technique" et l'éducation des utilisateurs restent les piliers de la résilience. Face à des acteurs comme le groupe Lazarus, la cybersécurité est devenue, selon les termes de l'agence singapourienne CSA, un véritable **« sport d'équipe »** où le facteur humain demeure le maillon le plus décisif.